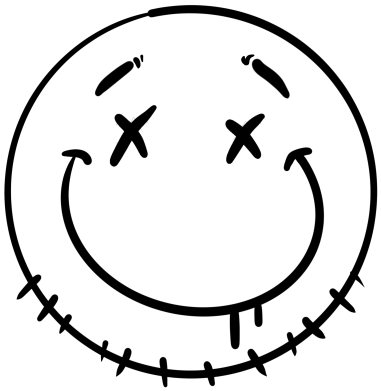

Lab 10: Vulnerability Scanning

Keith Schoen

CSEC3755-001

Dr. Daniel Pittman

16 April 2026

Contents

1 Network Discovery with Nmap **1**

1.1 Host Discovery Scan 1

1.2 Service Version Detection 2

1.3 OS Detection 4

1.4 Documentation 5

2 Nmap Vulnerability Scanning (NSE) **7**

2.1 General Vulnerability Scan 7

2.2 Targeted Service Scripts 7

2.3 CVE Findings 8

3 OpenVAS Full Scan **9**

3.1 Creating a Scan Target 9

3.2 Creating and Running a Scan Task 9

4 Vulnerability Analysis & Prioritization **11**

4.1 Top-10 Findings 11

4.2 Identifying False Positives 13

4.3 Making the Case 13

5 Remediation Plan **14**

5.1 Remediation Template 14

1 Network Discovery with Nmap

1.1 Host Discovery Scan

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap 10.0.2.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 09:41 -0600
Nmap scan report for 10.0.2.4
Host is up (0.00048s latency).
Not shown: 993 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
25/tcp   open  smtp
80/tcp   open  http
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3306/tcp open  mysql
MAC Address: 08:00:27:C5:60:28 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.79 seconds
```

Figure 1: Nmap host discovery scan results.

1.2 Service Version Detection

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -sV -sC -p- -oA lab10-ubuntu-discovery 10.0.2.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 23:12 -0600
Nmap scan report for 10.0.2.4
Host is up (0.00046s latency).
Not shown: 65528 closed tcp ports (reset)
PORT     STATE SERVICE      VERSION
21/tcp   open  ftp          vsftpd 2.0.8 or later
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxr-xr-x    1 0        0            4096 Apr 08 16:03 confidential
|_drwxr-xr-x    1 0        0            4096 Apr 08 16:03 public
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 10.0.2.15
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 3
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
22/tcp   open  ssh          OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; pro
tocol 2.0)
| ssh-hostkey:
|   256 20:75:da:dc:38:50:82:c1:3d:73:8f:14:0c:a5:e8:35 (ECDSA)
|_  256 d2:7a:f5:7a:83:ac:dd:b5:3d:cb:19:91:37:0d:30:b4 (ED25519)
25/tcp   open  smtp
|_smtp-commands: mail.medtech.local, SIZE 33554432, 8BITMIME, SMTPUTF8, HELP
| fingerprint-strings:
|   GenericLines:
|     220 mail.medtech.local MedTech Solutions SMTP Server v1.4 Ready
|     Error: bad syntax
|     Error: bad syntax
|   GetRequest:
|     220 mail.medtech.local MedTech Solutions SMTP Server v1.4 Ready
|     Error: command "GET" not recognized
|     Error: bad syntax
|   Hello:
|     220 mail.medtech.local MedTech Solutions SMTP Server v1.4 Ready
|     Syntax: EHLO hostname
|   Help:
|     220 mail.medtech.local MedTech Solutions SMTP Server v1.4 Ready
|     Supported commands: AUTH DATA EHLO HELO HELP MAIL NOOP QUIT RCPT RSET VRFY
|   NULL:
|_    220 mail.medtech.local MedTech Solutions SMTP Server v1.4 Ready
80/tcp   open  http         Werkzeug httpd 2.2.0 (Python 3.9.25)
|_http-server-header: Werkzeug/2.2.0 Python/3.9.25
| http-title: MedTech Patient Portal - Login
|_Requested resource was /login
139/tcp  open  netbios-ssn?
445/tcp  open  netbios-ssn  Samba smbd 4.15.13-Ubuntu (workgroup: MEDTECH)
3306/tcp open  mysql        MySQL 8.0.45
| ssl-cert: Subject: commonName=MySQL_Server_8.0.45_Auto_Generated_Server_Certif
icate
| Not valid before: 2026-04-09T17:29:40
|_Not valid after:  2036-04-06T17:29:40
|_ssl-date: TLS randomness does not represent time
| mysql-info:
|   Protocol: 10
|   Version: 8.0.45
|   Thread ID: 114
|   Capabilities flags: 65535
|   Some Capabilities: Support41Auth, SupportsCompression, IgnoreSpaceBeforePare
nthesis, FoundRows, SupportsLoadDataLocal, SupportsTransactions, ODBCClient, Ign
oreSigpipes, ConnectWithDatabase, DontAllowDatabaseTableColumn, LongColumnFlag,
LongPassword, SwitchToSSLAfterHandshake, InteractiveClient, Speaks41ProtocolNew,
 Speaks41ProtocolOld, SupportsMultipleResults, SupportsMultipleStatments, Suppor
tsAuthPlugins
|   Status: Autocommit
|   Salt: \\x083W\x07vm\x04jG   V\x14\x0576@\x0B\x05t
|   Auth Plugin Name: caching sha2 password
```

```
1 service unrecognized despite returning data. If you know the service/version,
please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?n
ew-service :
SF-Port25-TCP:V=7.98%I=7%D=4/12%Time=69DC7B43%P=x86_64-pc-linux-gnu%r(NULL
SF:,41,"220\x20mail\.medtech\.local\x20MedTech\x20Solutions\x20SMTP\x20Ser
SF:ver\x20v1\.4\x20Ready\r\n")%r(Hello,5C,"220\x20mail\.medtech\.local\x20
SF:MedTech\x20Solutions\x20SMTP\x20Server\x20v1\.4\x20Ready\r\n501\x20Synt
SF:ax:\x20EHLO\x20hostname\r\n")%r(Help,91,"220\x20mail\.medtech\.local\x2
SF:0MedTech\x20Solutions\x20SMTP\x20Server\x20v1\.4\x20Ready\r\n250\x20Sup
SF:ported\x20commands:\x20AUTH\x20DATA\x20EHLO\x20HELO\x20HELP\x20MAIL\x20
SF:NOOP\x20QUIT\x20RCPT\x20RSET\x20VRFY\r\n")%r(GenericLines,6F,"220\x20ma
SF:il\.medtech\.local\x20MedTech\x20Solutions\x20SMTP\x20Server\x20v1\.4\x
SF:20Ready\r\n500\x20Error:\x20bad\x20syntax\r\n500\x20Error:\x20bad\x20sy
SF:ntax\r\n")%r(GetRequest,81,"220\x20mail\.medtech\.local\x20MedTech\x20S
SF:olutions\x20SMTP\x20Server\x20v1\.4\x20Ready\r\n500\x20Error:\x20comman
SF:d\x20\"GET\"\x20not\x20recognized\r\n500\x20Error:\x20bad\x20syntax\r\n
SF:");
MAC Address: 08:00:27:C5:60:28 (Oracle VirtualBox virtual NIC)
Service Info: Host: 6C3D442378D3; OS: Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-security-mode:
|   3.1.1:
|_    Message signing enabled but not required
| smb-os-discovery:
|   OS: Windows 6.1 (Samba 4.15.13-Ubuntu)
|   Computer name: 6c3d442378d3
|   NetBIOS computer name: 6C3D442378D3\x00
|   Domain name:
|   FQDN: 6c3d442378d3
|_  System time: 2026-04-13T05:15:27+00:00
|_clock-skew: mean: 40s, deviation: 1s, median: 39s
| smb2-time:
|   date: 2026-04-13T05:15:26
|_  start_date: N/A
| smb-security-mode:
|   account_used: guest
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

Service detection performed. Please report any incorrect results at https://nmap
.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 166.75 seconds
```

Figure 2: Nmap service version detection results.

1.3 OS Detection

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap -O 10.0.2.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-12 23:24 -0600
Nmap scan report for 10.0.2.4
Host is up (0.00071s latency).
Not shown: 993 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
25/tcp   open  smtp
80/tcp   open  http
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3306/tcp open  mysql
MAC Address: 08:00:27:C5:60:28 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.19
Network Distance: 1 hop

OS detection performed. Please report any incorrect results at https://nmap.org/
submit/ .
Nmap done: 1 IP address (1 host up) scanned in 2.34 seconds
```

Figure 3: Nmap OS detection results.

1.4 Documentation

Port & Protocol	**Service Name & Version**	**What this service does**	**Should it be externally accessible and why**
21 TCP	FTP (vsftpd 2.0.8+)	File Transfer Protocol, used for transferring files between hosts; this instance allows anonymous login with no encryption.	No. Unencrypted and anonymous access is a serious risk; use SFTP instead.
22 TCP	SSH (OpenSSH 9.6p1)	Secure Shell, used for secure remote login and command execution.	Limited. Restrict to known IPs or a VPN; never expose to the open internet.
25 TCP	SMTP (MedTech SMTP v1.4)	Simple Mail Transfer Protocol, used for sending emails between servers.	No. Open SMTP relays invite spam abuse; the VRFY command is also exposed, creating a user enumeration risk.
80 TCP	HTTP (Werkzeug 2.2.0/Python 3.9.25)	Hypertext Transfer Protocol, used for serving web pages.	No. A patient portal must use HTTPS (port 443); plain HTTP transmits credentials and PHI in cleartext.

Port & Protocol	**Service Name & Version**	**What this service does**	**Should it be externally accessible and why**
139 TCP	NetBIOS-SSN (Samba, legacy)	Legacy Windows networking protocol used for file and printer sharing on local networks.	No. NetBIOS should never be internet-facing; it is a common target for lateral movement attacks.
445 TCP	SMB (Samba 4.15.13-Ubuntu)	Windows file-sharing protocol that allows shared drives and printers across a network.	No. SMB exposed externally is extremely dangerous (WannaCry, EternalBlue); message signing is also disabled on this host.
3306 TCP	MySQL (MySQL 8.0.45)	Relational database management system storing application data.	No. Databases should never be directly internet-facing; access should only occur via the application layer on localhost.

Table 1: Documentation of discovered services.

After logging my inital findings, I rand the results through Claude to see what else it found. The final three entries (and the note about VRFY in port 25) are results of its findings.

2 Nmap Vulnerability Scanning (NSE)

2.1 General Vulnerability Scan

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap --script vuln -oA lab10-ubuntu-nse 10.0.2.4
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 00:47 -0600
Nmap scan report for 10.0.2.4
Host is up (0.00072s latency).
Not shown: 993 closed tcp ports (reset)
PORT     STATE SERVICE
21/tcp   open  ftp
22/tcp   open  ssh
25/tcp   open  smtp
| smtp-vuln-cve2010-4344:
|_  The SMTP server is not Exim: NOT VULNERABLE
80/tcp   open  http
|_http-dombased-xss: Couldn't find any DOM based XSS.
| http-sql-injection:
|   Possible sqli for forms:
|     Form at path: /login, form's action: /login. Fields that might be vulnerab
le:
|       username
|     Form at path: /login, form's action: /login. Fields that might be vulnerab
le:
|_      username
|_http-stored-xss: Couldn't find any stored XSS vulnerabilities.
| http-csrf:
| Spidering limited to: maxdepth=3; maxpagecount=20; withinhost=10.0.2.4
|   Found the following possible CSRF vulnerabilities:
|
|     Path: http://10.0.2.4:80/
|     Form id:
|     Form action: /login
|
|     Path: http://10.0.2.4:80/login
|     Form id:
|_    Form action: /login
| http-slowloris-check:
|   VULNERABLE:
|   Slowloris DOS attack
|     State: LIKELY VULNERABLE
|     IDs:  CVE:CVE-2007-6750
|       Slowloris tries to keep many connections to the target web server open a
nd hold
|       them open as long as possible.  It accomplishes this by opening connecti
ons to
|       the target web server and sending a partial request. By doing so, it sta
rves
|       the http server's resources causing Denial Of Service.
|
|     Disclosure date: 2009-09-17
|     References:
|       http://ha.ckers.org/slowloris/
|_      https://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2007-6750
139/tcp  open  netbios-ssn
445/tcp  open  microsoft-ds
3306/tcp open  mysql
MAC Address: 08:00:27:C5:60:28 (Oracle VirtualBox virtual NIC)

Host script results:
| smb-vuln-regsvc-dos:
|   VULNERABLE:
|   Service regsvc in Microsoft Windows systems vulnerable to denial of service
|     State: VULNERABLE
|       The service regsvc in Microsoft Windows 2000 systems is vulnerable to de
nial of service caused by a null deference
|       pointer. This script will crash the service if it is vulnerable. This vu
lnerability was discovered by Ron Bowes
|       while working on smb-enum-sessions.
|_
|_smb-vuln-ms10-061: false
|_smb-vuln-ms10-054: false

Nmap done: 1 IP address (1 host up) scanned in 522.45 seconds
```

Figure 4: Nmap vulnerability scan results.

2.2 Targeted Service Scripts

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap --script ftp-anon -p 21 10.0.2.4
[sudo] password for kali:
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:52 -0600
Nmap scan report for 10.0.2.4
Host is up (0.00094s latency).

PORT   STATE SERVICE
21/tcp open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
| drwxr-xr-x    1 0        0            4096 Apr 08 16:03 confidential
|_drwxr-xr-x    1 0        0            4096 Apr 08 16:03 public
MAC Address: 08:00:27:C5:60:28 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.85 seconds
```

Figure 5: Nmap targeted FTP (port 21) service script results.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap --script "smb-vuln-*" -p 445 10.0.2.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:54 -0600
Nmap scan report for 10.0.2.4
Host is up (0.00076s latency).

PORT    STATE SERVICE
445/tcp open  microsoft-ds
MAC Address: 08:00:27:C5:60:28 (Oracle VirtualBox virtual NIC)

Host script results:
|_smb-vuln-ms10-054: false
| smb-vuln-regsvc-dos:
|   VULNERABLE:
|   Service regsvc in Microsoft Windows systems vulnerable to denial of service
|     State: VULNERABLE
|       The service regsvc in Microsoft Windows 2000 systems is vulnerable to de
nial of service caused by a null deference
|       pointer. This script will crash the service if it is vulnerable. This vu
lnerability was discovered by Ron Bowes
|       while working on smb-enum-sessions.
|_
|_smb-vuln-ms10-061: false

Nmap done: 1 IP address (1 host up) scanned in 17.54 seconds
```

Figure 6: Nmap targeted SMB (port 445) service script results.

```
┌──(kali㉿kali)-[~]
└─$ sudo nmap --script mysql-empty-password -p 3306 10.0.2.4
Starting Nmap 7.98 ( https://nmap.org ) at 2026-04-13 10:56 -0600
Nmap scan report for 10.0.2.4
Host is up (0.00076s latency).

PORT     STATE SERVICE
3306/tcp open  mysql
MAC Address: 08:00:27:C5:60:28 (Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 0.63 seconds
```

Figure 7: Nmap targeted MySQL (port 3306) service script results.

2.3 CVE Findings

CVE-2002-0597 (Port 445)

- **CVSS Score:** 5.0 (Medium)
- **Description:** LANMAN service on Microsoft Windows 2000 allows remote attackers to cause a denial of service (CPU/memory exhaustion) via a stream of malformed data to microsoft-ds port 445.

CVE-2026-33643 (Port 3306)

- **CVSS Score:** N/A (not yet scored)
- **Description:** SQL Injection vulnerability in SchemaHero 0.23.0 via the column parameter to the mysqlColumnAsInsert function in file plugins/mysql/lib/column.go.

3 OpenVAS Full Scan

3.1 Creating a Scan Target

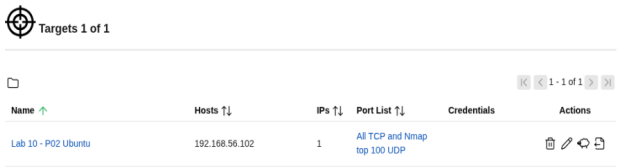

Figure 8: OpenVAS scan target configuration.

3.2 Creating and Running a Scan Task

Note about the lab: This part was messy, to put it likely. I ran into one reoccurring problem over a couple of dozens of scans where the scans themselves just seemed to slide off of the target. Logs showed that ever scan was starting and ending without running any plugins against the target (although it was discovered alive).

After over six hours of troubleshooting, I nuked the gvm build and restarted from scratch. This still failed to fix the issue, so troubleshooting continued.

I started noticing that when I would check my ip addresses, one of the two channels on either of my machines would continually drop their IP and connection. With some help from Claude, I was able to force IP loads on both machines and I was able to download the needed plugins and run my scan.

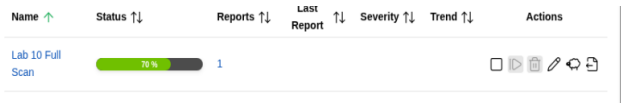

Figure 9: OpenVAS scan in progress.

Figure 10: OpenVAS scan results.

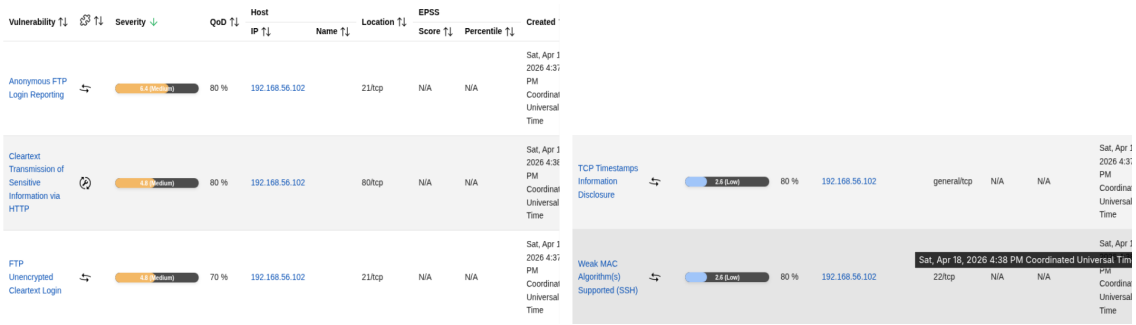

Figure 11: OpenVAS scan top 5 findings.

4 Vulnerability Analysis & Prioritization

4.1 Top-10 Findings

Priority		
High	**Medium**	**Low**

#	Finding	CVE	CVSS Score	Severity	Port	Description	Source
1	Anonymous FTP Login Reporting	CVE-1999-0497	6.4	Med.	21/tcp	Reports if the remote FTP Server allows anonymous logins.	OpenVAS
2	DoS via LANMAN Service	CVE-2002-0597	5.0	Med	445/tcp	Remote attackers can cause a denial of service via a stream of malformed data.	Nmap
3	Cleartext Transmission of Sensitive Information via HTTP	N/A	4.8	Med.	80/tcp	Attacker could use this to compromise or eavesdrop on the HTTP comms between the client and server.	OpenVAS
4	Unencrypted Cleartext Login	N/A	4.8	Med.	21/tcp	The remote host is running an FTP service that allows cleartext logins over unencrypted connections.	OpenVAS

#	Finding	CVE	CVSS Score	Severity	Port	Description	Source
5	SQL Injection via SchemaHero 0.23.0	CVE-2026-33643	N/A	N/A	3306/tcp	SQL Injection vulnerability in SchemaHero 0.23.0 via the column parameter to the mysqlColumnAsInsert function in file plugins/mysql/lib/column.go	Nmap
6	Weak MAC Algorithm Supported (SSH)	N/A	2.6	Low	22/tcp	The remote host supports a weak MAC algorithm in SSH connections.	OpenVAS
7	TCP Timestamp Info Disclosure	N/A	2.6	Low	22/tcp	The remote host implements TCP timestamps and therefore allows to compute the uptime.	OpenVAS
8	ICMP Timestamp Reply Information Disclosure	CVE-1999-0524	2.1	Low	general/icmp	The remote host resonded ton ICMP timestamp request.	OpenVAS

Note: First, I apologize for the short list. These were all the vulnerabilities that my scans were able to find.

Additionally, I want to note the process of making this list. The information contained comes directly from GreenBone/OpenVAS reports and nvd.nist.gov. However, when beginning my priority assessment, it was clear that some information would be difficult to obtain as every

government site I accessed has a brief disclosure about funding cuts at the top. As such, I had a hard time finding information on CVEs older than a couple of years.

Since I hit this bump, I consulted with Claude to see what it thought of the list, what sort of information it could gather, and where it would get it from. It came up with sound reasoning behind its findings and let me know the following:

"One heads-up worth noting in your report: NVD is currently redirecting CVE detail pages rather than serving them directly, which is consistent with the funding/maintenance issues you mentioned. The scores I've cited come from Tenable, Greenbone/OpenVAS, and CVEdetails as secondary sources..."

4.2 Identifying False Positives

Looking over my reports, only one of the findings stands out as a (most certain) false positive, that being #2 on my lists: CVE-2002-0597.

The vulnerability according to NIST is described as: "LANMAN service on *Microsoft Windows 2000* allows remote attackers to cause a denial of service (CPU/memory exhaustion) via a stream of malformed data to microsoft-ds port 445."

Admittedly, because I work with Windows machines regularly, I skimmed passed this as legitimate. After all, SQL injections are serious. But it kept bothering me until it finally clicked that the target is an Ubuntu machine, not Windows.

I think the status of this one as a false positive should be obvious as the vulnerability is just not compatible with the target's operating system.

4.3 Making the Case

Based on my findings and taking into consideration the tight window that Meridian Analytics has for immediate maintenance, I suggest that numbers 1, 4, and 3 from the list be fixed in the order given. This short-list contains three high-problem areas that should be addressed immediately as they make unwanted system access extremely easy. Fortunately, each of

these fixes should be able to be implemented easily with little problem.

5 Remediation Plan

5.1 Remediation Template

- **Vulnerability Name**: Anonymous FTP Login Reported
- **CVSS Score / Severity**: 6.4 / Medium
- **What Fixes It**: Disable anonymous logins by altering /etc/vsftpd.conf using the `sudo nano` command.
  1. Once open, find and alter the anonymous login line: `anonymous_enable=YES` to `NO`
  2. If the line does not exist, add it to the file.
  3. Restart the service with command `sudo systemctl restart vsftpd`.
- **Remediation Risk**: There will be a brief window of downtime when the service is restarted. All FTP transfers active at that moment will be dropped and may cause minor disruptions in production. Additionally, the `public` directory may suggest that there are dependencies using the anonymous FTP. Before running the fix, check this directory for dependencies and adjust accordingly.
- **Verification**: Run command `ftp 127.0.0.1` and attempt to log in anonymously. It should be rejected.
- **Priority**: Immediate

- **Vulnerability Name**: FTP Unencrypted Cleartext Login
- **CVSS Score / Severity**: 4.8 / Medium
- **What Fixes It**: Enable FTPS by following these steps:
  1. Generate a self-signed SSL certificate by running command `sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 -keyout /etc/ssl/private/vsftpd.key -out /etc/ssl/certs/vsftpd.crt`. Fill out the fields when propted.
  2. Open the vsftpd config file with command `sudo nano /etc/vsftpd.conf`.
  3. Add/update the following lines:

     ```
     ssl_enable=YES
     allow_anon_ssl=NO
     force_local_data_ssl=YES
     force_local_logins_ssl=YES
     ssl_tlsv1=YES
     ssl_sslv2=NO
     ssl_sslv3=NO
     rsa_cert_file=/etc/ssl/certs/vsftpd.crt
     rsa_private_key_file=/etc/ssl/private/vsftpd.key
     ```
  4. Restart vsftpd by running command `sudo systemctl restart vsftpd`.
- **Remediation Risk**: **Client compatibility breaks** - Any client that was connecting via plain FTP will stop working once `force_local_data_ssl=YES` and `force_local_logins_ssl=YE` are set. Because these lines are absolutely necessary for encryption, you must inventory all clients connecting to the server before implementing those lines.

  Firewall/Port Considerations - FTPS can require additional ports beyond 21 to function. These ports will need to be defined in vsftpd.conf and opened in the firewall.

  Certificate management overhead - Make note of when the certificate will expire

as it will need to be renewed.

Consider a staged roll-out where FTPS is enabled alongside FTP and migrate clients before finalizing the change.

- **Verification**: Run command `curl --ssl-reqd ftp://127.0.0.1 -u username:password -k`. The -k flag ignores the self-signed cert warning. If it connects, the FTPS is working.
- **Priority**: Immediate

- **Vulnerability Name**: Cleartext Transmission of Sensitive Information via HTTP
- **CVSS Score / Severity**: 4.8 / Medium
- **What Fixes It**: This is a two part fix:
  - **Part 1 - Enable HTTPS (SSL/TLS)**
    1. Create a certificate with the command `sudo openssl req -x509 -nodes -days 365 -newkey rsa:2048 -keyout /etc/ssl/private/medtech.key -out /etc/ssl/certs/medtech.crt`
    2. Enable HTTPS in Werkzeug by running the following Python code:

```
if __name__ == '__main__':
    app.run(
        host='0.0.0.0',
        port=443,
        ssl_context=(
            '/etc/ssl/certs/medtech.crt',
            '/etc/ssl/private/medtech.key'
        )
    )
```

  - **Part 2 - Force HTTP to HTTPS Redirect** by running the following Python code in Werkzeug:

```
from flask import request, redirect, url_for

@app.before_request
def enforce_https():
    if not request.is_secure:
        url = request.url.replace('http://', 'https://', 1)
        return redirect(url, code=301)
```

- **Remediation Risk**: **Application Breakage** - If there are any hardcoded `http://` URLs internally, mixed content, or any interal service-to-service calls using plain

HTTPS, they will break as soon as HTTPS is implemented. The entire codebase will have to be audited before and after the implementation. **Session and cookie invalidation** - Session cookies set without the `Secure` flag will not transfer to HTTPS. Existing user session will likely be lost. **Port conflicts** - Moving to port 443 means that it will need to be available and open. If there is anything else listening on port 443, it will create conflict. Additionally, port 80 will need to stay open for the redirect.

- **Verification**: Test the redirect by running command `curl -I https://192.168.56.102/login`. This should return `301 Moved Permanently`. Test the HTTPS connection by running command `curl -k https://192.168.56.102/login`. The -k flag bypasses the self-signed cert warning. If you get the login page back, HTTPS is working.

- **Priority**: Immediate

++report written with (minimal) help from Claude (Sonnet 4.6)++